ENGINEERING RELEASE REPORT

Multimodal AI Chatbot

Production Readiness & Final Release Checklist

PROJECT	Multimodal AI Chatbot MVP
STACK	React + Vite • FastAPI • SQLAlchemy • Gemini
REVIEW BASIS	Source and configuration files inspected from supplied ZIP
REVIEW DATE	29 October 2026

ROYAL GOLD EDITION • INTERNAL PROJECT REVIEW

This report separates implemented capabilities from production launch requirements. It is a readiness assessment, not a claim that the application has passed runtime, security, or load testing.

01 Executive summary

The supplied project is a feature-rich multimodal chatbot MVP with a React/Vite frontend and a FastAPI backend. Its documented scope includes text chat, image and camera input, speech transcription and text-to-speech, document retrieval/editing, web search, and generated files. The codebase has a useful modular structure, but several settings and deployment assumptions must be hardened before exposing it publicly.

READINESS AREA	ASSESSMENT	WHY IT MATTERS
Feature scope	Implemented in source; runtime verification still required	Avoid describing every feature as tested until each workflow passes.
Local development	Promising	Windows launcher scripts and install instructions are present.
Security posture	Needs hardening	Wildcard CORS, development defaults, local files and secrets require review.
Deployment readiness	Not yet production-ready	Environment-specific configuration, monitoring, access controls and tests are not evidenced as complete.

Release recommendation

Do not deploy this ZIP as-is to a public production environment. First remove secrets and local user data from the release bundle, tighten CORS and debug settings, verify file-serving behavior, replace machine-specific paths, and run the test/security checklist in this report.

What was reviewed

- README and documented setup/feature claims.
- Backend app entry point, settings, database session, file validation utility and requirements.
- Frontend package manifest and API client/proxy configuration.
- The ZIP file listing, including local database, environment file, uploads and generated outputs.

Validation limitation: source inspection only. No application was started, no tests were executed, and no production deployment was performed for this report.

02 Product scope & architecture

Architecture at a glance

REACT + VITE FRONTEND
Chat UI • Camera capture • File upload • Voice input • Settings • API client
HTTPS / reverse proxy / API base URL
FASTAPI BACKEND
Chat • Audio • Documents • Search • Health routes
Services: LLM • RAG • Speech • Image generation • File security
DATABASE + FILE STORAGE + EXTERNAL AI/SEARCH SERVICES
SQLAlchemy • PostgreSQL/SQLite fallback • uploads/generated directories

Documented capabilities

CAPABILITY	SCOPE / VERIFICATION NOTE
Conversational AI	Chat endpoint and conversation-history operations are represented in the API client.
Vision & camera	Image upload and browser camera capture are documented in the README/UI components.
Voice	Audio transcription and speech playback flows are documented; browser speech recognition may depend on browser support.
Document workflows	PDF/DOCX/TXT ingestion, RAG-style question answering, and non-destructive document editing are documented.
Web search	DuckDuckGo search integration and citation synthesis are described in the project README.
File generation	Generated documents, images and audio are supported by service modules and local storage directories.
3D golden UI	React components and styling assets indicate a dark/royal-gold interface with a 3D background.

03 Production blockers & risk register

Resolve the critical/high items before a public launch. These findings are based on the inspected source and ZIP contents; confirm each against the actual deployment configuration.

LEVEL	FINDING	REQUIRED ACTION
CRITICAL	**Secrets and local data in ZIP**	The supplied ZIP contains backend/.env plus a local database, uploaded files and generated outputs. Never publish credentials or user files. Rotate any key that may already have been exposed; exclude local data from release artifacts and repository history.
HIGH	**Wildcard CORS with credentials**	The FastAPI entry point configures allow_origins=['*'] and allow_credentials=True. Set explicit trusted frontend origins per environment and verify preflight behavior.
HIGH	**Development defaults**	Settings default to ENVIRONMENT='development' and DEBUG=True. Set production-safe defaults and fail fast if required production variables are missing.
HIGH	**Static serving of uploaded/generated content**	The app mounts /uploads and /generated. Define whether files are public, use opaque access controls where needed, prevent private document exposure, and set retention/deletion rules.
HIGH	**Machine-specific ZIP download path**	The download endpoint checks hard-coded Windows paths. Replace this with a configured path or remove the endpoint if not required.
HIGH	**Authentication / abuse controls not evidenced**	No auth or rate-limit layer is evident in the reviewed entry point/API client. Decide access model; protect costly AI endpoints, uploads, conversation data and generated files.
MEDIUM	**Database fallback and migrations**	PostgreSQL connection failure silently switches to local SQLite. Make production database behavior explicit and add a migration strategy, backup and restore tests.
MEDIUM	**Upload validation depth**	Extension validation and filename sanitization exist. Add size enforcement, content/MIME validation, safe parser handling, malware scanning if appropriate, and tests for malicious files.
MEDIUM	**Observability and reliability**	Logging exists, but production monitoring, structured redaction, error tracking, health/dependency checks and alerting are not evidenced.

04 Final production checklist

Use this as the release gate. Mark each item only after it has been verified in the target environment.

A. Repository & secrets

■	Remove backend/.env from release/repository; commit only .env.example with placeholders.
■	Remove local database, uploads, generated documents/images/audio, test captures and personal files from the release bundle.
■	Ensure .gitignore covers .env*, database files, uploads/generated contents, virtual environments, node_modules and build output.
■	If a real key was committed or shared, revoke/rotate it and check Git history; deleting the file in a later commit does not erase history.
■	Keep test scripts only when intentional, documented and free of secrets or private sample data.

B. Backend & API

■	Set explicit production environment variables; disable debug/reload in production.
■	Restrict CORS to exact production frontend origins.
■	Add authentication/authorization if this is not a strictly private single-user deployment.
■	Add rate limits, request timeouts, concurrency limits and cost safeguards for AI endpoints.
■	Validate file size, extension, content type and parser behavior; enforce upload quotas and retention policy.
■	Secure static file access; ensure private uploads/documents cannot be fetched by guessing a URL.
■	Remove or reconfigure the hard-coded ZIP download route.
■	Add database migrations, backups, restore test and a clear policy for PostgreSQL failures.

C. Frontend & deployment

■	Run npm ci and npm run build; fix all build/lint errors and review dependency advisories.
■	Configure API base URL and reverse proxy for production HTTPS; do not rely on the Vite development proxy.
■	Deploy behind HTTPS with correct security headers and a restrictive Content Security Policy where feasible.
■	Verify mobile/responsive layout, camera permission flows, microphone permission flows and graceful browser fallbacks.
■	Document build/start/deploy/rollback steps and required environment variables.

D. QA, operations & release

■	Run backend unit/integration tests and frontend build; document pass/fail evidence.
■	Test happy paths and failures for chat, image, audio, document upload/edit, web search and file download.
■	Test unsupported file types, oversized files, malformed documents, empty inputs, timeouts and AI provider outages.
■	Add structured logs with secrets and personal content redacted; monitor errors, latency, availability and AI spend.
■	Verify backups, retention/deletion, privacy notice, dependency licensing and incident/rollback procedure.
■	Run a small load test and security review before inviting external users.

05 Verification plan & release decision

Recommended smoke-test matrix

AREA	PASS CRITERIA	RESULT
Startup	Fresh install from clean checkout; environment configured; backend health endpoint returns expected status.	■ Not run
Chat	Text prompt succeeds; empty/invalid input is rejected; provider timeout returns a safe error.	■ Not run
Vision	Valid image upload and camera capture work; unsupported/oversized files are rejected.	■ Not run
Audio	Microphone permissions, transcription, TTS playback and browser fallback paths are checked.	■ Not run
Documents / RAG	PDF/DOCX/TXT ingest, grounded Q&A;, non-destructive edit and generated download are verified.	■ Not run
Web search	Search intent works; sources/citations are accurate enough; provider failure degrades safely.	■ Not run
Security	CORS rejects untrusted origins; no unauthenticated access to private files; secrets absent from logs and repo.	■ Not run
Operations	Logs, health checks, backup/restore, monitoring and rollback are exercised.	■ Not run

Go / no-go decision

CURRENT DECISION
NO-GO for public production release until critical/high items are resolved and verification evidence is recorded.
Recommended release sequence: (1) clean repository and rotate exposed credentials if applicable; (2) harden configuration and file access; (3) add access/rate controls; (4) run test matrix; (5) deploy to staging; (6) verify monitoring/backups; (7) approve production rollout.

Project notes

The supplied README documents a Windows one-click launcher and local development ports (frontend 5173, backend 8000). Production hosting will need deployment-specific commands and configuration. This report is a practical checklist based on the files provided; it does not replace a security audit, privacy/legal review, or runtime testing.

Prepared for project release planning • Royal Gold / Midnight theme